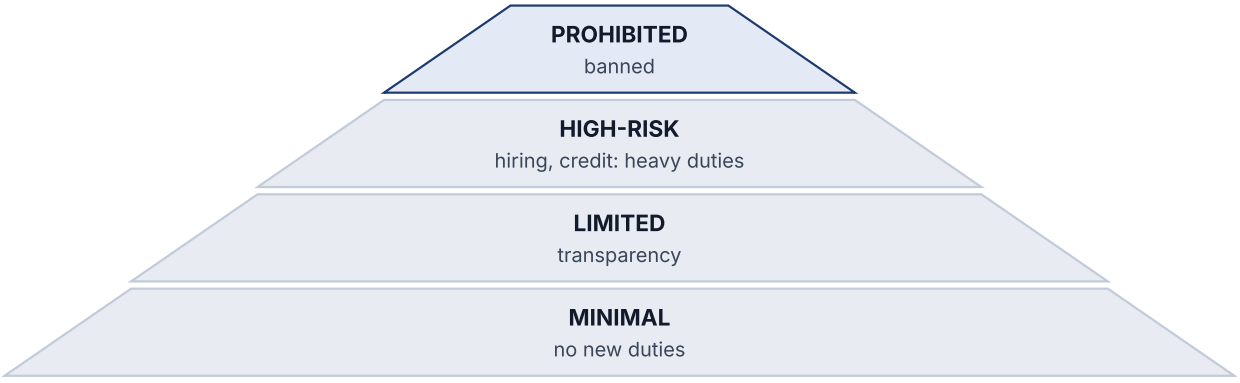
Governance, Risk & Responsible AI

1. The EU AI Act: risk tiers

The anchor regulation every other regime borrows from. It's **extraterritorial**: it applies to any system whose outputs are used in the EU.

- **Prohibited**: social scoring, manipulative techniques, most real-time biometric surveillance (banned since early 2025)
- **High-risk**: hiring, credit, insurance, education, critical infrastructure. Allowed with heavy obligations (risk management, data governance, documentation, human oversight, conformity assessment). Originally due August 2026; the 2026 AI Omnibus moved stand-alone systems to **2 December 2027** and AI in regulated products to **2 August 2028**
- **Limited-risk**: transparency (people must know they're talking to AI; synthetic content disclosed)
- **Minimal-risk**: most applications, no new obligations

✎ DIAGRAM



Obligations scale with risk. Classify the use case first, because the tier decides the obligations.

2. Frameworks clients ask about

- **NIST AI RMF**: voluntary US framework, four functions: **Govern, Map, Measure, Manage**
- **ISO/IEC 42001**: the certifiable AI management system (the ISO 27001 of AI)
- Gulf: **UAE PDPL** (plus DIFC and ADGM rules) and **Saudi PDPL** with data-transfer restrictions, so data residency is a real architectural constraint

3. Minimum viable governance (weeks, not years)

1. An **AI inventory**: every system, purpose, risk class, owner and data touched, including **shadow AI**
2. Risk classification at intake
3. Documentation by design (model cards, data provenance, eval results)
4. Human oversight proportionate to risk
5. Fairness testing where systems touch people's opportunities
6. Incident response
7. A review forum with authority to say no

Framed right, governance is an enabler: the organisations that deploy fastest are the ones whose governance lets legal and security say yes quickly.

4. Fairness and bias

- Where bias comes from: **historical** (past unfair decisions), **representation** (groups under-represented), **measurement** (a poor proxy label), and **proxy variables** (postcode standing in for a protected trait even after it's removed)
- **Demographic parity**: similar positive-outcome rates across groups
- **Equal opportunity**: qualified people approved at similar rates (equal true-positive rates)
- **Equalised odds**: similar true-positive and false-positive rates

> ⚠ These definitions conflict mathematically; choosing one is a policy decision for the client, not a technical default.

- Measure outcomes and error rates **per group**; mitigate before, during or after training; keep human review and an appeal route
- **Explainability**: global (what drives the model overall) vs local (why this person: **SHAP values**, **counterfactuals** like 'approved if income were X higher')
- For LLMs, test with paired prompts that differ only in a name or dialect

✎ DIAGRAM



Fairness is measured per group, chosen as policy, and backed by explanations people can challenge.

SAY IT

"First I'd classify the use case by risk tier, because that decides the obligations. For anything touching people's opportunities I'd measure outcomes per group, agree which fairness definition applies, and make each decision explainable."